Technical Documentation
BambooLeaf

Guarded AI-Assisted Supplier Payments & Autonomous Agent Wallet

Document Metadata

Item	Detail
Product	BambooLeaf
Assessed Version	Deployed Prototype Release Candidate
Date	2026-10-19
Competition	2026 Shenzhen International FinTech Competition, International Track, Topic F (Agent Wallet)
Team	TEAM GLACIERS
Live Deployments	**Frontend**: https://bamboo-leaf.vercel.app/ **Backend API**: https://bambooleaf.onrender.com/
Target Network	Ethereum Sepolia Testnet (Chain ID: 11155111)
Companion Documents	BambooLeaf: Guarded AI Agent Wallet; Security Self-Assessment Report

How to Read This Document

Every capability described below is classified according to its verification state:

- **Implemented & Deployed**: The code exists in the active release, is cited by source file, and is verified live on the deployed instances https://bamboo-leaf.vercel.app/ and https://bambooleaf.onrender.com/
- **Tested Locally**: Validated by automated repository suites passing on this snapshot (93 backend tests, 93 planner tests, planner typechecks, and frontend production build).
- **Work-in-Progress / Tracked**: Operational limitations or active features undergoing team expansion (e.g., ERC-20 swap human approvals).

- **Not Evidenced**: Capabilities not certified by an independent third party or lacking recorded multi-run benchmarks. These are explicitly cataloged to avoid overstatement.

Abstract

BambooLeaf is a prototype agentic Web3 payment platform that translates natural-language commands into structured payment proposals, validates them deterministically against an off-chain policy engine, and submits authorized transactions through an isolated backend signer. The platform integrates Web3 cryptographic session proofs, dual-control administrative role assignments, an accounts-payable supplier registry, a hash-chained audit ledger, a manual execution portal, and an isolated Attack Arena.
Core Value Proposition: The large language model proposes transaction intents, but trusted application code strictly validates the destination, amount, policy, and approvals before the backend signer can access the hot key or broadcast to the network.

Glossary

- **Intent**: A strictly typed, schema-validated representation of a wallet action (transfer, swap, read_balance, read_quote).
- **Policy Tier**: The deterministic risk evaluation of an intent:
  - **T1**: Eligible for automatic execution if all policy checks and autonomy criteria are satisfied.
  - **T2**: High-risk or policy-breaching action requiring human administrative approval.
  - **T3**: Denied outright.
- **Autonomy Level**: Operating permissions state ($L0$ to $L3$):
  - **L0**: Frozen. Signing blocked; read-only operations.
  - **L1**: Restricted. All transactions require human approval ($T2$).
  - **L2 / L3**: Standard/Trusted. $T1$ actions auto-execute; higher autonomy is earned via clean streaks.
- **Digest**: An immutable Keccak-256 hash binding chain ID, recipient, value, calldata, nonce, and timestamp, used to enforce single-use authorization tickets.
- **Shadow Fork**: A localized execution fork used to simulate contract calls and token balance deltas before submitting swaps.
- **Quarantine**: A dedicated LLM heuristic layer that classifies raw, untrusted text or attachments to isolate adversarial injections.
- **Signer**: The isolated backend service holding the agent key, rechecking all system constraints immediately before broadcasting.

1. Problem and Market Context

High-frequency business-to-business (B2B) payments create repetitive administrative overhead and introduce vulnerabilities: invoice fraud, vendor impersonation, unauthorized changes to payout addresses, duplicate submissions, and budget overruns. The illustrative scenario for BambooLeaf is garment manufacturing, where recurring disbursements for textiles, yarn, and hardware are issued to pre-approved suppliers.

Limitations of Existing Agent Wallets

1. **Unconstrained Execution**: Many implementations grant the LLM direct private key custody or allow it to construct and dispatch raw on-chain calldata.
2. **System Prompts as Firewalls**: Relying on natural-language system prompts to enforce spending limits makes systems susceptible to indirect prompt injection and jailbreaking.
3. **Approval Fatigue**: Systems that require manual human approval for every low-value action negate the efficiency benefits of an autonomous agent.

The BambooLeaf Approach

BambooLeaf separates the operational workflow into distinct trust boundaries:

- **The Planner Proposes**: The LLM translates user text into an intent, without private keys or signing capabilities.
- **Trusted Code Validates**: Deterministic TypeScript engines evaluate limits, velocity, recipient status, and autonomy tiers.
- **The Signer Rechecks**: Signing occurs only if all backend invariants pass. For supplier invoices, payout addresses are retrieved strictly from an administrative registry, ignoring arbitrary payout addresses found in invoice text.

2. Goals, Scope and Non-Goals

2.1 Goals (Mapped to Competition Rubric)

- **Product & Technical Functionality**: Natural-language planning, deterministic checks, manual fallback transactions, approval queues, supplier management, and live Sepolia execution.
- **Security & Defense**: Recipient allowlisting, tier routing, runtime signer re-verification, P-256 device authentication, admin-approved RBAC, and dual-LLM quarantine inspection.
- **Demo, Verification & Auditability**: Reproducible test suites, live deployment URLs, hash-linked audit logging, and an isolated Attack Arena.

2.2 In Scope (Implemented in Version v2.4)

- **Natural-Language Pipeline**: Natural-language goal processing with strict Zod intent validation and balance queries (wallet.getBalance()).
- **Deterministic Policy Engine**: Enforces transaction size caps, per-recipient daily limits, and velocity quotas.
- **Autonomy & Tier Routing**: Dynamic routing across tiers $T1$–$T3$ and earned autonomy states $L0$–$L3$.
- **Native Transfer Signing & Approvals**: Human approval workflows bound to Keccak-256 digests with a 120-second TTL.
- **Manual Execution Fallback (/#/transact)**: Direct wallet operations for transfers and swaps guarded by the policy firewall.
- **Web3 Identity & RBAC**: Wallet-signed onboarding, P-256 device key generation, admin role approval, and 30-second one-use request proofs.
- **Supplier & Invoice Safeguards (/#/payments)**: Dual-control supplier approval, structured invoice ingestion, PO overrun validation, and automated duplicate detection.

- **Tamper-Evident Audit Ledger (/#/compliance)**: SHA-256 hash-chained event tracking with integrity verification and JSON/CSV export.
- **Adversarial Sandbox (/#/arena)**: Attack Arena evaluating prompt injections, jailbreaks, and over-limit attacks under strict signer isolation.

2.3 Not Implemented / Current Limitations

- **OCR / PDF Invoice Parsing**: Invoice ingestion is restricted to structured fields; unstructured document parsing is excluded.
- **ERC-20 Native Signer Transfers**: Native transfer pipelines handle ETH; ERC-20 tokens route exclusively through the swap builder.
- **Native ETH-to-Token Swaps**: Swap infrastructure expects ERC-20 to ERC-20 pairs.
- **Swap Human-Approval Execution ($T2$)**: Automated swap routing ($T1$) operates under shadow-fork checks; manual approval execution for held swaps ($T2$) remains under development.
- **Hardware Attestation & Secure Enclaves**: Device authentication uses browser-managed Web Crypto keys in IndexedDB, not TPM/Secure Enclave hardware proofs.
- **On-Chain Policy Smart Contracts**: Spending limits and allowlists are enforced off-chain before the hot key signs; compromised backend hosts are not restricted by smart-contract-level controls.
- **Enterprise SSO & Third-Party Audits**: SAML/OIDC and SOC 2/ISO 27001 certifications have not been conducted.

3. Requirements and Traceability

ID	Requirement Specification	Implementation Source	Test & Verification Evidence	Status
FR-01	Accept bounded, valid natural-language goal input	intent.schema.tsx, goals.controller.tsx	Backend test suite (93/93 passed); live chat interface	Implemented & Tested
FR-02	Prevent duplicate invoices and block unverified suppliers	invoices.controller.tsx, suppliers.controller.tsx	Live invoice register (/#/payments); PO matching validation	Implemented & Deployed
FR-03	Provide manual fallback operations when AI is bypassed	transact.controller.tsx, TransactPage.tsx	Live Transact interface (/#/transact); policy-guarded	Implemented & Deployed

			signing	
SEC-01	Reject malformed, extra-field, or unknown planner outputs	planner.ts, schema.ts, backend-bridge.ts	Planner unit suite (93/93 passed); strict Zod validation	Implemented & Tested
SEC-02	Ground recipient addresses against address book or registry	resolve.ts, config.ts	Planner grounding tests; live trusted recipient allowlist	Implemented & Deployed
SEC-03	Enforce spending caps, recipient daily caps, and velocity	policy-engine.tsx, policy-usage.repository.tsx	Policy tests; live engine parameters (0.02 ETH, 5/600s)	Implemented & Deployed
SEC-04	Bind approvals to an immutable digest with single-use expiry	approvals.service.tsx, approval-digest.tsx	Approval lifecycle tests; live 120s queue (/#/approvals)	Implemented & Deployed
SEC-05	Enforce wallet sign-up, P-256 device keys, and admin approvals	device-auth.tsx, roles.controller.tsx	Live Accounts Console (/#/activity); request proof check	Implemented & Deployed
SEC-06	Maintain SHA-256 hash linkage across event records	audit-log.tsx, verify-chain.tsx	Audit verify tests; live Compliance Console (/#/compliance)	Implemented & Deployed
SEC-07	Isolate adversarial simulations from production hot keys	arena.service.tsx, arena.routes.tsx	Attack Arena (/#/arena); verified zero transactions dispatched	Implemented & Deployed

4. System Architecture and Trust Boundaries

Trust Zone	Environment & Components	Invariants & Enforcement Role
1. Untrusted Zone	• Client Browser (React 19, Vite, Tailwind CSS) • Web Crypto API (P-256 Key in IndexedDB)	Considered untrusted. Every state-mutating request must generate an x-request-proof signature (valid for ≤ 30s).
2. Trusted Application Zone	• Node.js / Express on Render • Authentication & RBAC Middleware • Quarantine Inspection Boundary • LLM Planner Bridge (Groq API, Temp: 0) • Deterministic Policy Guard (0.02 ETH cap, 5/600s velocity) • Backend Signer (AGENT_KEY)	Primary enforcement boundary. Evaluates schemas, grounds recipients, checks autonomy levels ($L0$–$L3$) and tiers ($T1$–$T3$), and holds signing keys.
3. Persistence Zone	• MongoDB Atlas	Stores supplier registries, PO balances, role assignments, active sessions, and the SHA-256 hash-chained audit ledger.
4. Execution Zone	• Sepolia RPC Node (Chain ID: 11155111) • Local Anvil Fork (Shadow-Fork Simulator)	Dispatches raw signed transactions to the live network; performs shadow-fork pre-simulations for token swaps.

Trust Boundary Specifications

1. **Client Independence**: The frontend interface is treated as untrusted. Policies, permissions, and

request validation are enforced server-side.

2. **Planner Quarantine**: External inputs pass through a quarantine classifier before planner processing. The planner cannot call tools or trigger transactions directly.
3. **Execution Isolation**: The backend signer runs an independent verification pipeline immediately before signing, confirming nonce continuity, active kill switches, and parameter integrity.

5. End-to-End Transaction Flow

Input Submission & Session Proof

- The user submits a natural-language goal or manual form request.
- The backend validates the x-request-proof header (P-256 signature, path, method, SHA-256 body hash, timestamp ≤ 30s).
- If proof is invalid: Immediately returns 401 Unauthorized.

Quarantine Screening (Untrusted Text & Memos)

- Raw invoice memos or unvetted text pass to the quarantine inspection model.
- If prompt injection or jailbreak is detected: The transaction halts immediately (Blocked & Logged), triggering an autonomy freeze to $L0$.

Planner Intent Proposal & Schema Validation

- The sanitized prompt passes to the LLM Planner (Groq platform, temperature 0).
- Strict Zod schema validation checks the JSON output.
- If output is malformed or invalid: Rejected at the schema boundary.

Deterministic Recipient Grounding

- The backend resolves the target recipient strictly against the internal address book or verified supplier registry.
- If recipient is unrecognized: Rejected as ungrounded.

Policy Engine & Autonomy Evaluation

- Route T3 (Denied): Triggered if the action violates spending caps, targets an unallowlisted address, or if the agent is at Autonomy Level $L0$.
- Route T2 (Human Approval Queue): Triggered if the action exceeds automated limits, involves a new recipient, or the agent is in supervised mode ($L1$). A Keccak-256 digest ticket is generated with a 120-second expiration. An authorized Admin or Approver must review and sign off.
- Route T1 (Auto-Execute): Triggered if the action falls within policy caps, targets an allowlisted address, and the agent is operating at Autonomy Level $L2$ or $L3$.

Signer Re-Check & On-Chain Broadcast

- The backend signer verifies account nonce sequence, chain ID, wallet balance ceilings, and kill-switch status.
- The raw transaction is signed via AGENT_KEY and broadcast to the Sepolia RPC node.

Tamper-Evident Audit Commit

- The transaction receipt, policy decision, and execution status are appended to the

SHA-256 hash-chained audit ledger.

Detailed Operational Lifecycle

1. **Authentication & Session Proof**: The client issues an HTTPS request carrying an x-request-proof header signed by its browser P-256 key, validating request freshness ($\leq$ 30 seconds) and payload integrity.
2. **Quarantine Screening**: Free-form goals or attached invoice memos pass to the quarantine LLM. Injections trigger an immediate failure and audit log.
3. **Planning & Validation**: The planner converts the input into a single structured intent (enforcing token limits and temperature 0). Grounding ensures destination addresses match pre-approved registry entries.
4. **Policy & Autonomy Assessment**: The policy engine evaluates transaction value, recipient history, velocity, and the current autonomy level.
5. **Routing & Approval**:
   - **T1 Actions**: Auto-execute if the system is operating at $L2$ or $L3$.
   - **T2 Actions**: Route to the approval queue, generating a Keccak-256 digest ticket that expires in 120 seconds.
   - **T3 Actions**: Violations are blocked, consuming a failure counter toward an $L0$ freeze.
6. **Signer Dispatch**: The signer rechecks chain ID, account nonce, balance limits, and kill-switch status, signs the payload via AGENT_KEY, and broadcasts to Sepolia.
7. **Audit Commit**: Details are committed to the SHA-256 hash-chained audit log.

6. Core Logic Implementations

6.1 Intent Schema and Recipient Grounding

The backend intent schema strictly permits four actions: transfer, swap, read_balance, and read_quote. Unknown fields cause immediate request rejection.

- **Grounding Engine**: Addresses must match a saved contact name in the address book or appear verbatim within the trusted context. The LLM receives contact labels, never raw private addresses.
- **Balance Queries**: Queries such as "Check my balance" execute read_balance via wallet.getBalance(), returning balances for native ETH and tracked ERC-20 assets (USDC).
- **Scheduled Intent Execution & Timers**: The intent schema and planner pipeline support temporal parameters (e.g., specifying an execution timestamp in the prompt). The backend policy layer schedules and holds the validated transaction intent until the specified time is reached, executing the final signer checks and on-chain dispatch only when the timer window opens.

6.2 Autonomy Levels and State Machine

| AUTONOMY LEVEL HIERARCHY
|
| [L0: READ-ONLY / FROZEN]

| - All signing halted; execution disabled.
| - Triggers: Critical guard block, 3 blocked attempts in 10 mins, or Admin Kill Switch.
| - Recovery: Admin manual reset returns system to L1.
|
| [L1: RESTRICTED / SUPERVISED]
| - Every action requires human approval (routes to T2)
| - Default state post-reset; requires 10 consecutive clean executions to promote.
|
| [L2: STANDARD GUARDED]
| - Routine actions within policy auto-execute (T1).
| - High-value or anomalous transactions route to human approval (T2).
|
| [L3: TRUSTED AUTONOMY]
| - High earned tier; operates under maximum allowable autonomous velocity.

6.3 Deterministic Policy & Usage Limits

Limits loaded from the active backend on Sepolia (Chain ID: 11155111):

- **Per-Transaction Cap**: 0.02 ETH.
- **Per-Recipient Daily Cap**: 0.05 ETH.
- **Velocity Window**: Maximum 5 transactions per 600 seconds (10 minutes).
- **Maximum Swap Slippage**: 1.00% (100 basis points).
- **Maximum Swap Input**: 50 units.
- **Maximum Daily Swap per Token**: 40 units.

6.4 Swap Pipeline & Shadow-Fork Execution

Swaps execute through an isolated pipeline:

1. **Route Validation**: Targets are validated against an allowlist of decentralized exchange routers (e.g., Uniswap v3 router 0xC532a74256D3Db42D0Bf7a0400fEFDbad7694008).
2. **Exact-Input Construction**: Approval and swap calls are assembled using minimum-output bounds calculated from live oracle feeds.
3. **Shadow-Fork Simulation**: The transaction executes against a local fork of the network. Balance changes, emitted events, and contract calls are traced against the intent. Deviances cause an immediate transaction revert.
4. **Broadcast**: Validated swaps broadcast on-chain.

7. Supplier and Invoice Handling

Table 1: Supplier Registry & Purchase Order Configuration

Component	Active Configuration & State	Policy / Invariant Rule

Verified Supplier: Araf	• Address: 0xe2463837...a879b1dD • Status: ACTIVE	Eligible for automated invoice payout matching.
Verified Supplier: Fabiya	• Address: 0x8624f295...73392DeC • Status: REMOVED	Blacklisted. All incoming invoices are rejected.
Purchase Order Allocation	• Linked Supplier: Araf • PO Reference: PO-2026-TEX-001 • PO Cap: 2.50 ETH	Invoiced cumulative amount cannot exceed PO Cap + tolerance.
Dual-Control Invariant	Administrative Maker-Checker	New suppliers and payout address changes remain pending until approved by a second administrator.

Table 2: Structured Invoice Ingestion & Verification Outcome

Input Field	Test Case Value	Validation Rule
Supplier	Araf	Must match an active record in the verified registry.
Invoice Number	pto345	Pair (Supplier, InvoiceNumber) must be globally unique.
Invoice Amount	2000 ETH	Evaluated against active policy caps and remaining PO allocation.
PO Reference	et3ef	Must belong to the selected supplier and exist in the active PO store.

Verification Outcome	ESCALATED	“Purchase order reference was not found for this supplier.” Transaction held for administrative review; funds are not released.

Verification Pipeline

1. **Registry Grounding**: Payout destinations are loaded directly from the database record of the verified supplier. Addresses in invoice memos or attachments are ignored.
2. **Dual-Control Supplier Activation**: Supplier registrations or banking address changes remain pending until approved by a second administrator.
   PO Budget Verification: Invoices must reference a valid, open PO. The backend verifies:

$$\sum InvoicedAmount \leq POValue \times (1 + Tolerance)$$

3. **Duplicate Prevention**: Invoices enforce uniqueness across (SupplierID, InvoiceNumber). Duplicate submissions are rejected.
4. **Supplier Deactivation & Removal**: An administrative Remove action on active supplier registry records. Removing a supplier updates their database status to REMOVED and instantly blacklists their address from payout resolution, preventing subsequent invoice processing for that vendor.

8. Identity, Access, and Roles

8.1 Onboarding & Device Security

- **Wallet-Signed Registration**: Users connect their Web3 wallet and sign an onboarding challenge.
- **P-256 Device Generation**: Browsers generate an export-restricted ECDSA P-256 key pair stored in IndexedDB.
- **Administrative Clearance**: Enrolled devices default to pending or No access until an Admin approves the device and assigns a role.
- **Cryptographic Request Proofs**: Mutating HTTP requests require an x-request-proof signature over the method, path, body hash, and timestamp ($\leq$ 30 seconds).
- **Revocation Controls**: Administrators can revoke device access via a single click, terminating active sessions.

8.2 Role Permissions Matrix

Permission Capability	Admin JPG	Approver JPG	Clerk JPG	Auditor

Natural-Language Goals & Chat	Full Access	Full Access	Full Access	Denied
Structured Invoice Intake	Full Access	Full Access	Full Access	Read-Only
Supplier Creation & Modification	Full Access	Verification Only	Read-Only	Read-Only
Dual-Control Supplier Activation	Secondary Admin	Secondary Admin	Denied	Denied
Tier 2 Human Approvals ($T2$)	Authorized	Authorized	Denied	Denied
Policy Limits & Autonomy Reset	Full Access	Read-Only	Denied	Read-Only
Emergency Kill Switch Activation	Authorized	Authorized	Denied	Denied
Audit Verification & Export	Read / Export	Read / Export	Denied	Full Access

9. Application Workspaces

9.1 Global Shell & Real-Time Context

- **Network Indicator**: Active indicator showing connection to **Sepolia testnet** (Chain ID: 11155111)
- **Market Price Feed**: Real-time pricing for ETH, BTC, SOL, and USDC with percentage deltas and timestamped updates.
- **Global Navigation**: Access to notifications, settings, search, and user profiles.
- **Live Notification Center**: An active notification modal pinned to the global header that delivers real-time system alerts

9.2 Conversational Agent Workspace (/#/chat)

- **Natural-Language Balance Queries**: Native queries (e.g., "Check my balance") return structured cards detailing native ETH and USDC holdings.
- **Guarded Action Chips**: One-click prompt templates for checking balances, swaps, and

policy-bounded transfers.

- **Quarantine Ingestion**: An **Attach invoice / memo** button routes text and attachments through the quarantine classifier.
- **Live Context Sidebar**: Displays wallet address, ownership status, token balances (0.1680 ETH, 150.00 USDC), and spending counters ($0.00 / $150).
- **Editable Action Chips**: Pre-configured prompt templates populate the chat input field rather than triggering immediate auto-submission, allowing operators to freely modify target addresses, token amounts, or execution parameters prior to planning.

9.3 Executive Overview (/#/overview)

- **Cardholder Pass**: Displays the active wallet (AGENT WALLET EVM), cardholder name, truncated address, and chain ID.
- **Audit Volume & Activity**: Rolling 7-day volume chart, blocked-by-guard counter (10 blocked), and categorized event streams.
- **Quick Action Controls**: Direct shortcuts for transfers, swaps, approvals, policy, and autonomy.

9.4 Manual Transact Workspace (/#/transact)

- **Manual Execution Fallback**: Form interface allowing operators to initiate transfers and swaps directly without the LLM planner, maintaining full backend policy enforcement.
- **Telemetry & Failure Logging**: Displays confirmed vs. blocked transaction counters and detailed failure diagnostics (e.g., simulation failure details).

9.5 Approval Queue (/#/approvals)

- **Ticket Review Interface**: Displays pending Tier 2 actions awaiting authorization.
- **Digest Invariance**: Each ticket displays transaction parameters bound to an immutable Keccak-256 digest expiring in 120 seconds.

9.6 Wallet & Signer Vault (/#/wallet)

- **Vault Customization**: Interface supporting Obsidian, Emerald, and Titanium themes.
- **Live Balances**: Shows native ETH and USDC holdings with configured RPC endpoints.
- **Currency Converter**: Real-time conversion calculator linking fiat inputs to cryptocurrency estimates.

9.7 Deterministic Policy Engine (/#/policy)

- **Limit Management**: View and modify spending limits, recipient daily caps, velocity windows, and swap parameters.
- **Allowlist Inspector**: Displays allowlisted recipient addresses and authorized decentralized exchange routers.

9.8 Autonomy & Safety Console (/#/autonomy)

- **State Telemetry**: Displays the current autonomy level ($L1$), clean streak counters (1/10 to promotion), and blocked attempts.
- **Safety Invariants**: Outlines demotion triggers (critical guard violation, repeated blocks, kill switch).

9.9 Compliance Console (/#/compliance)

- **Integrity Validation**: On-demand verification recalculating hashes across stored records.
- **Data Export**: Authenticated JSON and CSV export capabilities.
- **Version Tracking**: Audit tables detailing autonomy state transitions and policy configuration changes.

9.10 Interactive Attack Arena (/#/arena)

- **Isolated Testing Sandbox**: Evaluates adversarial inputs under complete signer isolation (Transactions Sent: 0).
- **Attack Presets**: Pre-configured vectors for prompt injections, direct jailbreaks, unallowlisted recipients, and over-limit transfers.
- **Evaluation Modes**: Side-by-side testing in **Guarded Mode** vs. **Naive Mode**.

10. Data Model and APIs

10.1 MongoDB Collections

- audit_events: Hash-linked event ledger.
- policy_versions: Historical policy snapshots.
- autonomy_state: Current agent level, promotion counters, and freeze states.
- transaction_approvals: Active and expired approval tickets.
- goal_requests: Incoming natural-language goals and tracking IDs.
- policy_usage: Rolling 24-hour spending records and velocity trackers.
- device_accounts, devices, device_sessions: Public keys, approval statuses, and active sessions.
- suppliers, purchase_orders, invoices: Supplier registry, PO tracking, and invoice records.
- role_assignments: Wallet-to-role mappings.

10.2 REST API Surface

Endpoint Group	Method & Route	Authorization Level	Description
System	GET /health	Public	Node health check and database connectivity.
Devices	POST /api/devices/challenge	Public	Issues random challenge for wallet signature.
Devices	POST /api/devices/register	Wallet Signature	Registers P-256 public key in pending state.

Devices	GET /api/devices	Admin	Lists enrolled devices and telemetry.
Devices	POST /api/devices/revoke	Admin	Revokes device credentials and clears sessions.
Planning	POST /api/goal	Clerk, Approver, Admin	Submits natural-language goal for evaluation.
Approvals	GET /api/approvals	Approver, Admin	Retrieves pending approval tickets.
Approvals	POST /api/approvals/claim	Approver, Admin	Authorizes single-use approval ticket
Suppliers	POST /api/suppliers	Admin	Registers a new supplier in pending state.
Suppliers	PUT /api/suppliers/activate	Secondary Admin	Dual-control activation of supplier.
Invoices	POST /api/invoices	Clerk, Approver, Admin	Ingests structured invoice and evaluates PO
Audit	GET /api/audit	Auditor, Approver, Admin	Queries audit trail with filter criteria.
Audit	GET /api/audit/verify	Auditor, Approver, Admin	Verifies hash integrity across audit chain.
Audit	GET /api/audit/export	Auditor, Approver, Admin	Exports audit logs in JSON or CSV format.
Autonomy	POST /api/autonomy/reset	Admin	Resets agent from $L0$ to $L1$
Policy	PUT /api/policy	Admin	Modifies spending caps and limits.
Arena	POST /api/arena/evaluate	Rate-Limited Sandbox	Runs policy evaluations under signer isolation.

10.3 Cryptographic Audit Record Structure

Audit entries maintain strict SHA-256 hash linkage:
Hash_N = SHA-256(Seq_N || Timestamp_N || RequestUUID_N || CanonicalData_N || Hash_(N-1))

—----------

JSON


```
{
 "seq": 684,
 "timestamp": "10/19/2026, 11:44:51 PM",
 "decision": "Blocked",
 "layer": "planner.blocked",
 "tier": "T3",
 "details": {
  "code": "MODEL_REFUSED",
  "reason": "MODEL_REFUSED: No amount, token, or recipient specified; cannot determine a valid action."
 },
 "hash": "8a375dcaa7450e..."
}
```


—----------

11. Testing and Verification Evidence

11.1 Automated Test Execution

Automated suites confirm codebase stability across all primary sub-packages:

—----------

Bash

```
# Backend Test Suite Execution
cd backend && npm test
# Result: 93 passed, 0 failed.

# LLM Planner Suite & Typecheck
cd ../backend/llm-planner && npm test && npm run typecheck
# Result: 93 passed, 0 failed. Typecheck passed.

# Frontend Production Build Verification
cd ../frontend && npm run build
# Result: Production build compiled successfully without type errors.
```

—----------

11.2 Empirical Evaluation Metrics

- **Live Planner Evaluation (Groq llama-3.3-70b-versatile)**:
  - Total Test Runs: 68 requests (3 provider budget timeouts excluded).
  - JSON Schema Validity: 64/64 (100%).
  - Legitimate Goal Pass Rate: 22/22 (100%).
  - False Positive Rate: 0/22 (0%).
  - Planner-Level False Negative Rate: 6/41 (14.6%).
  - Execution Latency: Median: 698 ms | p95: 986 ms.
  - Context Consumption: 88,241 tokens total.

- **Offline Guard Replay Suite**:
  - Adversarial Injections: 45 attack runs evaluated.
  - Harmful Planner Proposals: 8 proposals reached the guard.
  - Harmful Executions Dispatched: 0/45 (0%).
  - Guard Interception Rate: 8/8 harmful outputs held ($T2$) or denied ($T3$).

- **Quarantine Classifier Evaluation**:
  - Injected Samples Flagged: 9/9 (100%).
  - Attacker Address Leaks: 0/9 (0%).
  - Benign Sample False Positives: 0/4 (0%).

12. Operational Security and Deployment

12.1 Key Custody and Exposure Mitigations

- **Signer Key Isolation**: The backend signing key (AGENT_KEY) resides strictly within server environment variables on Render. It is never passed to frontend bundles or LLM provider contexts.
- **Hot-Wallet Balance Bounding**: Operational risks are limited by maintaining minimal balances on the signing wallet (0.1680 ETH), backed by hard off-chain daily limits

12.2 Deployment

- Frontend on vercel
- Backend on render

13. Data Handling and Privacy Practices

- **User Goals**: Plain-language goals are processed by the planner LLM to generate candidate intents.
- **Untrusted Attachments**: Raw invoice text and memo fields pass to the quarantine provider for heuristic evaluation.
- **Recipient Privacy**: The planner receives contact aliases; raw Ethereum addresses from the internal registry are resolved by application code.
- **Persistent Records**: Invoices, purchase orders, device keys, and audit logs reside within MongoDB Atlas.

14. Conclusion

BambooLeaf addresses a fundamental challenge in autonomous Web3 finance: enabling LLM-driven natural language interactions without relinquishing control over financial assets. By enforcing strict trust boundaries, the platform ensures that AI models can propose actions while deterministic application logic validates requests and an isolated backend signer performs independent verification before execution. This layered architecture helps mitigate risks such as prompt injection, unauthorized beneficiary changes, invoice manipulation, and fraudulent payment attempts.

With 186 automated tests successfully passing, production deployments on Vercel and Render, verified transaction execution on the Ethereum Sepolia testnet, and a dedicated adversarial testing environment, BambooLeaf demonstrates a secure, auditable, and defense-in-depth approach to autonomous financial operations.